

[Logo UNAL]	Universidad Nacional de Colombia - sede Bogotá Facultad de Ingeniería Departamento de Sistemas e Industrial Curso: Ingeniería de Software 1 (2016701)
-------------	--

GESTIONAR ROLES Y PERMISOS DE USUARIO

El sistema gestiona los roles de Administrador, Bibliotecario y Estudiante, validando los permisos de acceso en cada acción realizada, y reservando al Administrador la facultad exclusiva de crear, editar o eliminar roles en el sistema.

ACTORES	REQUISITO
Administrador (actor principal — gestiona roles) Bibliotecario (actor secundario — opera con permisos asignados) Estudiante (actor secundario — accede con permisos restringidos) Sistema de gestión de accesos	RF_21 – Gestión de roles y permisos. El sistema debe gestionar los roles de Administrador, Bibliotecario y Estudiante, validando los permisos de acceso en cada acción realizada. El Administrador tendrá la facultad exclusiva de crear, editar o eliminar roles; el Bibliotecario estará autorizado para gestionar préstamos, devoluciones y actualizar el estado de los ejemplares; mientras que el Estudiante podrá buscar en el catálogo, realizar reservas y consultar su historial personal.

DESCRIPCIÓN

Este caso de uso describe cómo el sistema controla y aplica el esquema de roles y permisos que rige el acceso a todas las funcionalidades de la Biblioteca CyT. Existen tres roles predefinidos: Administrador, Bibliotecario y Estudiante. El Administrador es el único actor habilitado para crear nuevos roles, editar los permisos de roles existentes o eliminar roles del sistema. Cada vez que un usuario autenticado intenta ejecutar una acción, el sistema verifica en tiempo real que su rol activo tenga permiso para realizarla; si no lo tiene, bloquea la operación y notifica al usuario. El objetivo es garantizar que cada actor acceda únicamente a las funcionalidades que le corresponden según su perfil.

PRECONDICIONES

El usuario tiene una sesión activa en el sistema con un rol asignado (Administrador, Bibliotecario o Estudiante).

El rol asignado al usuario está registrado y activo en la base de datos del sistema.

El Administrador que desea crear, editar o eliminar un rol tiene permisos de administración global activos y sin restricciones vigentes.

FLUJO NORMAL

1. El usuario autenticado intenta acceder a un módulo o ejecutar una acción dentro del sistema.
2. El sistema intercepta la solicitud y extrae el rol activo del usuario desde la sesión.
3. El sistema consulta la tabla de permisos asociada al rol del usuario para la acción solicitada.
4. El sistema evalúa si el rol del usuario tiene permiso para realizar la acción solicitada.

- a. Si el usuario NO tiene permiso: el sistema bloquea la operación, muestra el mensaje: "Acceso denegado: no tienes permisos para realizar esta acción." y registra el intento en el log de auditoría. → El flujo finaliza.
 - b. Si el usuario SÍ tiene permiso: el sistema permite continuar con la acción solicitada.
5. El sistema permite que el usuario complete la acción dentro de su módulo correspondiente.
 6. Si el usuario es Administrador y accede al módulo de Gestión de roles, el sistema muestra el listado de roles existentes con sus permisos configurados.
 7. El Administrador selecciona una de las siguientes operaciones sobre un rol:
 - a. Crear nuevo rol: el sistema despliega un formulario para definir nombre del rol y conjunto de permisos. El Administrador completa el formulario y confirma. El sistema valida que el nombre del rol no exista previamente.
→ Si ya existe, muestra el mensaje: "Ya existe un rol con ese nombre. Por favor elige otro."
→ Vuelve al formulario.
 - b. Editar rol existente: el sistema despliega el formulario del rol seleccionado con sus permisos actuales. El Administrador modifica los campos deseados y confirma.
 - c. Eliminar rol: el sistema solicita confirmación antes de proceder. Si existen usuarios con ese rol activo, muestra advertencia: "Existen usuarios con este rol asignado. Reasigna sus roles antes de eliminarlo." → No permite la eliminación hasta que no haya usuarios con ese rol activo.
 8. El sistema persiste los cambios realizados sobre el rol en la base de datos y los aplica de forma inmediata a todos los usuarios que tengan ese rol asignado.
 9. El sistema registra la operación en el log de auditoría con timestamp, usuario Administrador responsable, tipo de operación (crear / editar / eliminar) y rol afectado.
 10. El sistema muestra al Administrador un mensaje de confirmación con el resumen de los cambios aplicados.

POSTCONDICIONES

Los permisos del rol creado, editado o eliminado quedan persistidos en la base de datos y se aplican de forma inmediata a todos los usuarios que lo tengan asignado.

Cualquier intento de acceso a una funcionalidad no autorizada queda bloqueado y registrado en el log de auditoría, independientemente de si la operación fue exitosa o no.

La operación de gestión de roles queda registrada en el log de auditoría con fecha, usuario responsable y detalle del cambio realizado.

Ningún usuario con rol distinto a Administrador puede modificar, crear ni eliminar roles en el sistema.

NOTAS

- Los tres roles base del sistema (Administrador, Bibliotecario, Estudiante) son predefinidos y no pueden ser eliminados; únicamente sus permisos pueden ser editados por el Administrador.
- La validación de permisos se ejecuta en cada solicitud del usuario, tanto en el frontend (ocultando elementos de UI no autorizados) como en el backend (rechazando peticiones no autorizadas), para garantizar seguridad ante manipulaciones directas de la API.
- Un usuario solo puede tener un rol activo simultáneamente. Si se requiere cambiar el rol de un usuario, el Administrador debe reasignarlo desde el módulo de gestión de usuarios; el cambio es efectivo de forma inmediata a partir de la siguiente solicitud del usuario.
- Este caso de uso es transversal al sistema: es invocado implícitamente en cada acción que requiera validación de acceso, por lo que no existe un punto de entrada único definido por el usuario.
- La eliminación de un rol solo es posible si ningún usuario activo lo tiene asignado actualmente. El sistema no permite la eliminación en caso contrario hasta que el Administrador reasigne

manualmente a los usuarios afectados.

MOCKUP

Vista del módulo de Gestión de roles (exclusivo para Administrador). Se presentan dos escenarios: acceso autorizado con panel de roles (izquierda) y acceso denegado a un usuario sin permisos (derecha).

Escenario A – Administrador: panel de roles

Gestión de roles y permisos

Rol activo: **Administrador**

Roles configurados en el sistema:

	Administrador	[Editar]
	Bibliotecario	[Editar]
	Estudiante	[Editar]

[+ Crear nuevo rol]

Permisos del rol seleccionado: Bibliotecario

- ☒ Gestionar préstamos y devoluciones
 - ☒ Actualizar estado de ejemplares
 - ☒ Registrar estado físico de ejemplares
 - ☒ Acceder a reportes y panel de monitoreo
 - ☐ Crear / editar / eliminar roles
 - ☐ Acceder a log de auditoría completo
- [Guardar cambios] [Cancelar]

 **Cambios guardados exitosamente.**

Escenario B – Acceso denegado (Estudiante)

Módulo: Gestión de roles y permisos

Rol activo: **Estudiante**

Acceso denegado

No tienes permisos para acceder a este módulo.
La gestión de roles es exclusiva del Administrador.

Acciones disponibles para tu rol:

-  Buscar en el catálogo bibliográfico
-  Realizar reservas de puestos de estudio
-  Consultar historial personal de uso
-  Gestión de roles (sin permiso)
-  Reportes y auditoría (sin permiso)

El intento de acceso ha sido registrado
en el log de auditoría del sistema.

[Volver al inicio]